FICHE 7 - SÉCURISER L'INFORMATIQUE MOBILE

Anticiper l'atteinte à la sécurité des données à l'extérieur des locaux, dont le vol ou la perte d'un équipement mobile.

La multiplication des pratiques de travail hors des locaux de l'organisme (ex. : déplacements, télétravail) et d'utilisation de l'équipement personnel des utilisateurs comporte des risques spécifiques liés à l'usage d'ordinateurs portables, de clés USB ou encore de smartphones : il est indispensable de les encadrer.

Les précautions élémentaires

- **Sensibiliser les utilisateurs aux risques spécifiques liés à l'utilisation d'outils informatiques mobiles** (ex. : vol de matériel, risques liés à la connexion aux réseaux et équipements non maîtrisés, notamment publics, usage d'équipements personnels) et aux procédures prévues pour les limiter.
- **Prévoir un contrôle d'accès** par des dispositifs d'authentification adaptées (ex. : certificat électronique, carte à puce). Tous les flux d'information devraient être chiffrés (ex. : VPN pour les accès externes).
- Mettre à disposition des utilisateurs **des espaces de stockage partagé accessibles en nomadisme.** Leur recommander d'y stocker toutes leurs données pour se prémunir contre la perte ou le vol du matériel.
- **Prévoir des moyens de chiffrement des postes nomades et supports de stockage amovibles** (ex. : ordinateur portable, clé USB, disque dur externe, CD-R, DVD-RW) tels que :
  - le chiffrement du disque dur (de nombreux systèmes d'exploitation intègrent une telle fonctionnalité) ;
  - le chiffrement fichier par fichier ;
  - la création de conteneurs (dossier susceptible de contenir plusieurs fichiers) chiffrés.
- **Concernant les *smartphones*,** en plus du code PIN de la carte SIM, **activer le verrouillage automatique du terminal et exiger un secret pour le déverrouiller** (ex. : mot de passe, schéma).
- **Informer les utilisateurs** de la personne à contacter en cas de perte ou de vol de leur matériel.
- **Évaluer les risques spécifiques à l'utilisation d'équipements personnels par les utilisateurs** (pratique du « *bring your own device* » ou BYOD) **et ne les autoriser qu'en fonction des risques identifiés**. Les données et les applications accessibles sur ces appareils non maîtrisés par l'organisme doivent être limitées en fonction de leur criticité. Les responsabilités de chacun et les précautions à respecter doivent être formalisées dans la charte informatique (voir la fiche n°2 - Définir un cadre pour les utilisateurs).

Ce qu'il ne faut pas faire

- Utiliser comme outil de sauvegarde ou de synchronisation les services *cloud* installés par défaut sur un appareil sans analyse approfondie de leurs conditions d'utilisation et des engagements de sécurité pris par les fournisseurs de ces services. Ceux-ci ne permettent généralement pas de respecter les préconisations données dans la fiche n°14 : Gérer la sous-traitance.
- Prévoir des mesures de sécurité (ex. : par le paramétrage d'un système de gestion des appareils mobiles ou MDM, « *mobile device management* ») qui entravent l'utilisation d'un équipement personnel dans le cadre privé (BYOD) au motif qu'il est utilisé dans le cadre professionnel (ex. : interdire l'installation d'applications sur l'appareil).
- Accéder à des éléments relevant de la vie privée des personnes stockés dans l'espace personnel d'un équipement personnel utilisé dans le cadre professionnel (BYOD).